CASE STUDY

The Year 2005 in Intrusions: A Dated Record

A TeamStarWolf case study. Published 13 November 2026; every source checked as of that date.

Executive summary

For most people, 2005 was the year a letter arrived saying a company had lost their personal data. ChoicePoint, a data broker, found in September 2004 that small-business "customers" in the Los Angeles area had opened accounts with stolen identities and altered documents and were pulling names, Social Security numbers, driver's licence numbers and some credit reports (Confirmed [1]). In February 2005 it notified about 35,000 Californians under a California law, then more people in later rounds: about 145,000 consumers in all 50 states by its own 10-K, 163,000 by the FTC's complaint, with at least 800 identity-theft cases (Confirmed [1][5]). In March LexisNexis reported misuse of legitimate customers' IDs and passwords at its Seisint unit, and by April it counted 59 incidents and about 310,000 people (Confirmed [8][9]). LexisNexis said hackers had not breached its infrastructure, and the FTC's account is of fraudulent applicants ChoicePoint approved, not of a network intrusion (Confirmed [9][6]). The data went out through the front door, on accounts the brokers had approved or customers had lost.

The card-data losses were real intrusions. DSW Shoe Warehouse reported the theft of card data from 103 stores on 8 March, and by 18 April the count was 108 stores, 1.4 million cards and 96,000 checks (Confirmed [10][11]). The FTC settled with BJ's Wholesale Club in June and proposed an order against DSW in December. In both cases it treated weak security as an unfair practice: card data kept that was not needed, commonly known or default passwords, and open wireless (Confirmed [14][13]). The FTC's later complaint against CardSystems Solutions, a card processor, alleges that an SQL injection attack in September 2004 installed programs that sent stored magnetic-stripe data out of the network every four days, exposing tens of millions of cards. Card issuers found the counterfeit fraud in early 2005 (Confirmed [15]). TJX's intruder first got in during July 2005 and was not found until December 2006 (Confirmed [17]). The e-commerce threats study is the home for that case.

On the vulnerability side, Microsoft fixed a Plug and Play buffer overflow on 9 August (MS05-039), and within days the Zotob worm was exploiting it against Windows 2000. The FBI said it disrupted networks at companies that included major US news organizations, and police in Morocco and Turkey arrested two suspects on 25 August (Confirmed [19][22][24]; the interval is Inferred). Microsoft's own advisory says only a small number of customers were affected (Confirmed [23]). The year ended with the Windows Metafile flaw, which US-CERT warned on 28 December was being exploited against fully patched Windows XP SP2 machines with no patch available. The fix came on 5 January 2006, outside the monthly cycle (Confirmed [34][38]). In between, CERT/CC found that copy-protection software on some Sony BMG music CDs hid itself with rootkit techniques and shipped an uninstaller that web pages could abuse (Confirmed [31]).

A US-CERT alert of 8 July described e-mail sent to chosen people, spoofed to look as if it came from colleagues, carrying trojans that, the alert says, appear to target US information for exfiltration; it urged government and critical-infrastructure owners to protect their data (Confirmed [43]). TIME's "Titan Rain" story of 29 August described a longer espionage campaign against defense laboratories and contractors, but with hedged attribution (Reported [44]). The Athens wiretaps came to light at Vodafone Greece in January to March (Reported [45]). Much of 2005's state record was published years later (Confirmed [46][48]; Inferred for the reading).

Regulators also settled a lot in 2005. Bank regulators set a breach-response and notice standard in March and April, and the FFIEC told banks in October that single-factor authentication might not be enough for internet banking (Confirmed [63][64][65]). The Energy Policy Act of 2005 made "cybersecurity protection" part of mandatory electric reliability standards (Confirmed [66]). NIST published the first SP 800-53 control catalog and FIPS 201, and ISO published ISO/IEC 27001:2005 (Confirmed [68][69][74]). CWE did not yet exist as a list, CAPEC came in 2007, and ATT&CK later still (its release date was not checked here), so every MITRE id in Part 9 is this study's later mapping (Confirmed [80][81]; Inferred for the bindings).

This study records the year by date. It is built only from sources opened on 12 and 13 November 2026 and from checks of the library's data run on 13 November 2026, and is checked as of 13 November 2026.

Key facts at a glance

Field	Value
Period	1 January to 31 December 2005, plus the records that open or close a 2005 event: ChoicePoint's discovery (27 Sep 2004), the CardSystems intrusion (Sep 2004), the 2001 to 2003 conduct behind the year's sentences, the 2006 and 2007 FTC settlements, MS06-001 (5 Jan 2006), Ancheta's sentence (8 May 2006), the Gonzalez charges (5 Aug 2008), and the vendor and government reports that date state tools to 2005 (2015, 2023)
Data-broker losses	ChoicePoint about 145,000 consumers (10-K) or 163,000 (FTC), at least 800 identity-theft cases; LexisNexis/Seisint 59 incidents, about 310,000 people; neither a network intrusion (Confirmed [6][9])
Card-data losses	DSW 108 stores, 1.4 million cards, 96,000 checks; CardSystems tens of millions of cards exposed; BJ's about $13 million in outstanding claims; TJX first access July 2005 (Confirmed [11][15][14][17])
FTC actions	BJ's (16 Jun 2005, final 23 Sep); DSW proposed order (1 Dec 2005); ChoicePoint ($10 million civil penalty plus $5 million redress, 26 Jan 2006); CardSystems (23 Feb 2006); Sony BMG (30 Jan 2007) (Confirmed [14][13][4][7][16][33])
Worms and botnets	Zotob and Mytob (from about mid-August, arrests 25 Aug); Ancheta's rxbot botnets (arrest 3 Nov); the Samy MySpace worm (4 Oct, author's account) (Confirmed [24][50]; Reported [42])
Exploited flaws	VERITAS Backup Exec Remote Agent, CVE-2005-0773 (TA05-180A, 29 Jun); Plug and Play, CVE-2005-1983 (Zotob); Windows Metafile, CVE-2005-4560 (exploited before any patch, 28 Dec) (Confirmed [25][22][34])
Other disclosed flaws	Cisco IOS IPv6 (Black Hat, 27 Jul); VERITAS hard-coded NDMP credentials (12 Aug); Sony BMG XCP uninstaller, CVE-2005-3650 (Nov) (Confirmed [28][27][31][32])
Microsoft	Bulletins MS05-001 (11 Jan) to MS05-055 (13 Dec); the WMF fix MS06-001 out of cycle on 5 Jan 2006 (Confirmed [39][40][38]; the count of 55 is Inferred)
CVE volume	5,010 CVE records with an NVD publication date in 2005 (Confirmed [41])
State record	TA05-189A targeted trojan e-mail (8 Jul); Titan Rain (TIME, 29 Aug, Reported); the Athens wiretaps found (Jan to Mar, Reported); Snake operations under way (Inferred from AA23-129A); EQUATIONDRUG in its 2003 to 2013 development span (Confirmed [43][46][48]; Reported [44][45])
Prosecutions	Jiang, Jacobsen, Lyttle, Greco, the RPCSDBOT juvenile (Feb to Mar); Operation Site Down (29 to 30 Jun); Jaschan (8 Jul, Reported); the Boston juvenile (8 Sep); Ancheta (3 Nov); Shadowcrew pleas (17 Nov) (Confirmed [57][53][56][54][55][60][52][50][58]; Reported [61])
Law and regulation	Interagency breach-response guidance (29 Mar); OCC Bulletin 2005-13 (14 Apr); GAO-05-231 (13 May); Energy Policy Act (8 Aug); FFIEC authentication guidance (12 Oct); Illinois PIPA enacted (Confirmed [63][64][62][66][65][67])
Standards	FIPS 201 (25 Feb); SP 800-53 (28 Feb); RFC 4033 and the SDL paper (Mar); FIRST takes CVSS (14 Apr); ISO/IEC 17799:2005 (10 Jun); ISO/IEC 27001:2005 (14 Oct); SP 800-40 v2 (16 Nov); SP 800-83 (23 Nov); SP 800-77 (1 Dec); RFC 4301 (Dec) (Confirmed [69][68][75][77][78][73][74][70][71][72][76])

Field	Value
This study's MITRE binding	31 ATT&CK Enterprise technique rows, all later mappings; no ATT&CK for ICS rows; Turla (G0010), Uroburos (S0022) and Equation (G0020) bound with dating caveats; no 2005 worm, botnet or rootkit has an ATT&CK software object; NVD's CWE-20 and CWE-94 plus study-class CWEs; CAPEC and D3FEND pairings from the library's data; one Enterprise Navigator layer (Part 9)

Key findings

- **The biggest consumer losses of the year were not hacks.** ChoicePoint lost data to applicants who lied about who they were, and LexisNexis to misused customer credentials. LexisNexis said its infrastructure was not breached, and the FTC describes fraudulent applicants ChoicePoint approved (Confirmed [5][6][9]). This study reads them as abuse of legitimate access (Inferred [6][9]).
- **Regulators began treating weak security as an unfair practice.** The FTC's DSW and CardSystems orders require a security program and independent assessments every two years for 20 years, and the BJ's order treated the same failures as unfair. ChoicePoint added the largest civil penalty in FTC history to that date (Confirmed [14][13][16][7]).
- **The card-data intrusions ran for months before anyone noticed.** CardSystems' exfiltration began in November 2004 and was found through counterfeit fraud in early 2005; TJX's intruder came in July 2005 and was found in December 2006 (Confirmed [15][17]).
- **Default, commonly known or weak passwords ran through the 2005 card cases.** BJ's used commonly known default user IDs and passwords, DSW a commonly known user ID and password, and CardSystems weak passwords; VERITAS backup software shipped hard-coded administrative credentials (Confirmed [14][13][16][27]).
- **Patch to worm took days.** MS05-039 came out on 9 August, and the FBI says Zotob was released less than two weeks before the 25 August arrests (Confirmed [19][24]). The interval is Inferred.
- **The year ended with a zero-day in a file format.** The Windows Metafile flaw was exploited against fully patched XP SP2 before Microsoft had a fix (Confirmed [34][35]).
- **A vendor's product shipped with a rootkit.** CERT/CC says the XCP software on some Sony BMG CDs used rootkit techniques to hide files, and the FTC's 2007 settlement says it created security vulnerabilities (Confirmed [31][33]).
- **Botnets became a prosecuted business.** DOJ called Ancheta's case the first prosecution of its kind. He sold botnet access for DDoS and spam and was paid adware commissions on about 400,000 machines (Confirmed [50]).
- **Targeted e-mail espionage got a government alert.** TA05-189A described spoofed, work-themed e-mail and trojans built to take data out, and named no actor (Confirmed [43]).

Top recommendations

1. **Vet the customer as well as the network.** ChoicePoint's loss came through approved accounts, and the FTC order requires credentialing (Confirmed [4][6]). Check identity, purpose and behavior for anyone who can query sensitive data.

2. **Do not keep card data you do not need.** BJ's kept data for up to 30 days and DSW kept data it no longer needed (Confirmed [14][13]). CardSystems stored magnetic-stripe data for up to 30 days (Confirmed [15]).
3. **Change every default and shared credential.** The FTC cites default or commonly known IDs and passwords at BJ's and DSW, and US-CERT cites hard-coded credentials in VERITAS products (Confirmed [14][13][27]).
4. **Test public web applications for injection.** The FTC's CardSystems order lists the failure to assess exposure to SQL injection (Confirmed [16]).
5. **Segment and control wireless.** DSW did not limit access through wireless access points or separate its store networks (Confirmed [13]).
6. **Watch outbound traffic.** CardSystems' data left on a schedule every four days for months (Confirmed [15]); scheduled exfiltration is visible on egress (Inferred).
7. **Treat backup agents as exposed services.** TA05-180A reported increased scanning of 10000/tcp and active exploitation of the Remote Agent flaw (Confirmed [25]).
8. **Block what the bulletin tells you to block.** MS05-039's workaround was to block TCP 139 and 445 at the firewall, and Windows 2000 was the main remote exposure (Confirmed [19]).
9. **Have a plan for an unpatched client flaw.** The WMF flaw was exploited for at least eight days before MS06-001 (Confirmed [34][38]; the interval is Inferred).
10. **Write the notice plan before the breach.** OCC Bulletin 2005-13 expected every bank to have a response program, notify customers as soon as possible when misuse was reasonably possible, and notify its regulator (Confirmed [64]).

Scope and method

This study covers intrusions, vulnerabilities, malware, prosecutions, regulation, standards and policy dated to 2005, plus the later records that open, close or explain a 2005 event. It follows the method of the case studies collection: primary sources first, every claim graded, and numbers given as the source states them. Sources were opened on 12 and 13 November 2026, and the library data checks were run on 13 November 2026.

Grade	Meaning in this study
Confirmed	The primary record was opened and states the fact: a company's SEC filing, an FTC complaint, order or release, a Justice Department or FBI release, a US-CERT alert in CISA's archive, a CERT/CC vulnerability note, a vendor bulletin or advisory, a CVE or NVD record, a statute or Federal Register notice, a bank regulator's issuance, a NIST, ISO, IETF, FIRST or MITRE record, a joint government advisory, a vendor research report stated as that vendor's own finding, a live ATT&CK page, or a library study that is the home for an event
Reported	Only a secondary source supports the fact: TIME on Titan Rain, IEEE Spectrum on the Athens wiretaps, the BBC on the Sasser conviction, and the Samy worm author's own account. The source is named in the text
Demonstrated	A check this study ran itself and saw the result: id, name, tactic and page checks in the library's data files and `mitre/` page tree
Inferred	The study's own reasoning, labelled where it appears. Every ATT&CK, CAPEC and D3FEND id bound to a 2005 event is Inferred as to the binding, and so is every CWE that NVD does not list

Charging documents, indictments and complaints are allegations; where this study cites one, the record confirms that the allegation was made, not that it was proven. Company filings are the company's own account.

Limits a reader should know:

- **CVE existed, but in candidate form.** 2005 bulletins and alerts cite CAN- candidate ids, and NVD now lists them as CVE- ids; both forms name the same record (Confirmed [19][22]). NVD gives a specific CWE for two of the four 2005 CVEs checked here (Confirmed [36][32][22][26]).
- **No contemporaneous ATT&CK, CWE or CAPEC.** In 2005 MITRE built PLOVER, a collection of more than 1,500 real-world vulnerability examples under 290 weakness types, for the DHS-sponsored NIST SAMATE project. The first CWE List followed in 2006 and CAPEC in 2007 (Confirmed [80][81]). Years before 2015 have no contemporaneous ATT&CK mapping in this series. Where ATT&CK itself dates an object to the period, Part 5 and Part 9 say so.
- **What was not checked.** No primary was opened for: MasterCard's June 2005 statement on CardSystems and the 40 million card figure often quoted with it; the July 2005 congressional hearings on CardSystems and the spring hearings on ChoicePoint and LexisNexis; Mark Russinovich's 31 October post on the Sony rootkit and the Texas Attorney General's suit against Sony BMG; the FFIEC's own press release (the FDIC's copy was used); the UK NISCC's June 2005 briefing on targeted trojan e-mail; the Greek ADAE and prosecutor reports on the Vodafone wiretaps; the 2005 report of the US-China Economic and Security Review Commission; any US government record on Titan Rain; the Sober worm variants; Cabir and Commwarrior; the Israeli trojan espionage affair; the Bank of America and Citigroup backup-tape losses; the Gary McKinnon extradition proceedings; Oracle's January 2005 Critical Patch Update; a court record of the Sasser verdict; the EU Framework Decision 2005/222/JHA; the PITAC report of February 2005; a primary for the 2005 SHA-1 collision research; Microsoft AntiSpyware's beta; NVD's launch date; the NERC CIP standards themselves; and the total number of state breach-notice laws passed in 2005. They are left out. Their absence here is not evidence that nothing happened.

Part 1: the year as a dated timeline

One row per event or report. The date is the event date where the source gives one, otherwise the publication date. Rows marked "frame" or "boundary" open or close a 2005 event.

Date	Event	Thread	Sector	Grade	Sources
2001 to 2002 (frame)	Juju Jiang installs keylogging software on Kinko's terminals (sentenced 28 Feb 2005). The 2003 plea: The Year 2003 in Intrusions	Crime	Retail services, consumers	Confirmed	[57]
2002-04 (frame)	The "Deceptive Duo" intrusions into federal agency systems and defacements (Lyttle plea 11 Mar 2005)	Crime	Government	Confirmed	[56]

Date	Event	Thread	Sector	Grade	Sources
2003-08-14 (frame)	The RPCSDBOT worm's DDoS takes Microsoft's main web site offline for about four hours (juvenile sentenced 11 Feb 2005). Home: dot-com era study; the 2003 arrest: The Year 2003 in Intrusions	Worm	Technology	Confirmed	[55]
2003-09 onward (frame)	TIME: Titan Rain intrusions begin with a Lockheed Martin break-in. The 2003 and 2004 parts: The Year 2003 in Intrusions, The Year 2004 in Intrusions	Espionage	Defense, government	Reported	[44]
Late 2003 to early 2004 (frame)	AA23-129A: the FSB develops Snake as "Uroburos"; initial versions complete around early 2004	Espionage	Government	Confirmed	[46]
2004-03 (frame)	A Massachusetts juvenile's 15-month spree begins (sentenced 8 Sep 2005)	Crime	Telecommunications, ISPs	Confirmed	[52]
2004-09 (frame)	CardSystems: SQL injection on its web application installs programs; exfiltration every four days from Nov 2004	Intrusion	Payment processing	Confirmed (as alleged)	[15]
2004-09-27 (frame)	ChoicePoint finds suspicious activity by Los Angeles-area small-business "customers"	Fraud	Data broker	Confirmed	[1]
2004-10-26 (frame)	Secret Service arrests Nicholas Jacobsen	Crime	Telecommunications	Confirmed	[53]
2004-10 to 2004-11 (frame)	Anthony Greco's program sends about 1.5 million spam messages	Crime	Social media	Confirmed	[54]
2005-01-11	MS05-001, the year's first Microsoft bulletin	Vulnerability	Technology	Confirmed	[39]
2005-01	The Massachusetts juvenile accesses a telephone provider's systems and posts a person's mobile phone data online	Crime	Telecommunications	Confirmed	[52]
2005-01-24	Undelivered text-message errors at Vodafone Greece; the start of the wiretap discovery	Espionage	Telecommunications	Reported	[45]
Early 2005	Card issuers find several million dollars of counterfeit-card fraud traced to CardSystems	Intrusion	Payment processing	Confirmed (as alleged)	[15]
2005-02	ChoicePoint notifies about 35,000 California consumers under a California law; later rounds follow	Fraud	Data broker	Confirmed	[5][1]

Date	Event	Thread	Sector	Grade	Sources
2005-02-11	The RPCSDBOT juvenile sentenced to three years of probation (W.D. Wash.)	Crime	Technology	Confirmed	[55]
2005-02-15	Jacobsen pleads guilty (C.D. Cal.); victims include T-Mobile	Crime	Telecommunications	Confirmed	[53]
2005-02-18 and 2005-02-22	Class actions filed against ChoicePoint; the SEC opens an informal inquiry	Regulation	Data broker	Confirmed	[1]
2005-02-25	NIST FIPS 201, Personal Identity Verification	Standards	Government	Confirmed	[69]
2005-02-28	NIST SP 800-53, the first federal control catalog; Jiang sentenced to 27 months (S.D.N.Y.)	Standards; Crime	Government; retail services	Confirmed	[68][57]
2005-03	RFC 4033 (DNSSEC-bis); Microsoft's updated SDL paper	Standards	Internet; technology	Confirmed	[75][77]
2005-03-04	ChoicePoint drops certain sensitive data products; Ericsson tells Vodafone Greece unauthorized software is installed in two central offices	Fraud; Espionage	Data broker; telecommunications	Confirmed; Reported	[2][45]
2005-03-08	Retail Ventures announces the DSW card-data theft, 103 stores	Intrusion	Retail	Confirmed	[10]
2005-03-09	Reed Elsevier reports fraudulent access at LexisNexis's Seisint unit; a Vodafone Greece network-planning head is found hanged	Fraud; Espionage	Data broker; telecommunications	Confirmed; Reported	[8][45]
2005-03-10	The Vodafone Greece CEO briefs the prime minister's office; five investigations follow	Espionage	Telecommunications	Reported	[45]
2005-03-11	Robert Lyttle pleads guilty (N.D. Cal.)	Crime	Government	Confirmed	[56]
2005-03-21	Greco pleads guilty to extortion threats against MySpace.com (C.D. Cal.)	Crime	Social media	Confirmed	[54]
2005-03-29	Interagency Guidance on Response Programs (70 FR 15736)	Regulation	Financial services	Confirmed	[63]
2005 Q1	ChoicePoint records a $5.4 million pre-tax charge for the fraudulent access	Fraud	Data broker	Confirmed	[3]
2005-04-12	LexisNexis: 59 incidents over two years, about 310,000 people	Fraud	Data broker	Confirmed	[9]
2005-04-14	OCC Bulletin 2005-13; FIRST chosen as CVSS custodian	Regulation; Standards	Financial services; cross-sector	Confirmed	[64][78]

Date	Event	Thread	Sector	Grade	Sources
2005-04-18	DSW findings: 108 stores, 1.4 million cards, 96,000 checks	Intrusion	Retail	Confirmed	[11]
2005-04-22	The original SP 800-53 withdrawn and replaced by an updated release	Standards	Government	Confirmed	[68]
2005-05-13	GAO-05-231 on spam, phishing and spyware (released 13 Jun)	Policy	Government	Confirmed	[62]
From about 2005-06	Max Butler allegedly hacks financial institutions and card processing centers. Home: Four Books on Cybercrime	Crime	Financial services	Confirmed (as alleged)	[59][92]
2005-06	TIME: Britain, Canada, Australia and New Zealand issue alerts referencing related activity; the Massachusetts juvenile runs a DDoS on a second telephone provider	Espionage; Crime	Government; telecommunications	Reported; Confirmed	[44][52]
2005-06-10	ISO/IEC 17799:2005	Standards	Cross-sector	Confirmed	[73]
2005-06-16	FTC settles with BJ's Wholesale Club	Regulation	Retail	Confirmed	[14]
2005-06-18	CVE-2005-0773 (VERITAS Backup Exec Remote Agent) published in NVD	Vulnerability	Cross-sector	Confirmed	[26]
2005-06-29	TA05-180A: the VERITAS flaw actively exploited, scanning on 10000/tcp up	Exploitation	Cross-sector	Confirmed	[25]
2005-06-29 to 2005-06-30	Operation Site Down: more than 90 searches in 11 countries against piracy groups	Crime	Software, media	Confirmed	[60]
2005-07	TJX's intruder first gets in. Home: E-Commerce Threats	Intrusion	Retail	Confirmed	[17][91]
2005-07-08	TA05-189A, Targeted Trojan Email Attacks; Sven Jaschan convicted for Sasser	Espionage; Crime	Government, critical infrastructure; technology	Confirmed; Reported	[43][61]
2005-07-27	The Cisco IOS IPv6 flaw disclosed at Black Hat	Vulnerability	Network infrastructure	Confirmed	[28][30]
2005-07-29	cisco-sa-20050729-ipv6 and TA05-210A	Vulnerability	Network infrastructure	Confirmed	[28][29][30]
2005-08-08	Energy Policy Act of 2005 enacted	Law	Energy	Confirmed	[66]
2005-08-09	MS05-039, Plug and Play; SA05-221A; VU#998653	Vulnerability	Cross-sector	Confirmed	[19][20][21]
2005-08-10	CVE-2005-1983 published in NVD	Vulnerability	Cross-sector	Confirmed	[22]

Date	Event	Thread	Sector	Grade	Sources
2005-08-11	Microsoft Security Advisory 899588 on Zotob (updated 17 Aug); Cisco's IPv6 advisory goes final	Worm; Vulnerability	Cross-sector; network infrastructure	Confirmed	[23][28]
2005-08-12	TA05-224A: VERITAS hard-coded NDMP credentials	Vulnerability	Cross-sector	Confirmed	[27]
About 2005-08-13 onward	Zotob and Mytob released; networks disrupted, including major US news organizations	Worm	Media, cross-sector	Inferred (date); Confirmed (effects)	[24]
2005-08-25	Farid Essebar arrested in Morocco and Atilla Ekici in Turkey (FBI release, 26 Aug)	Crime	Cross-sector	Confirmed	[24]
2005-08-29	TIME publishes "The Invasion of the Chinese Cyberspies" on Titan Rain	Espionage	Defense, government	Reported	[44]
2005-09-08	The Massachusetts juvenile sentenced to 11 months' detention	Crime	Telecommunications	Confirmed	[52]
2005-09-23	The FTC's BJ's order becomes final	Regulation	Retail	Confirmed	[14]
2005-10-04	The Samy worm spreads on MySpace (author's account)	Worm	Social media	Reported	[42]
2005-10-12	FFIEC, Authentication in an Internet Banking Environment	Regulation	Financial services	Confirmed	[65]
2005-10-14	ISO/IEC 27001:2005	Standards	Cross-sector	Confirmed	[74]
2005-11-02 and 2005-11-03	Jeanson James Ancheta indicted on 17 counts and arrested (C.D. Cal.)	Crime	Government, defense, consumers	Confirmed (as alleged)	[50]
2005-11-15 and 2005-11-16	VU#312073: Sony BMG's XCP software hides files with rootkit techniques; its uninstaller is unsafe	Vulnerability	Consumers, media	Confirmed	[31]
2005-11-16	NIST SP 800-40 Version 2, patch and vulnerability management	Standards	Government	Confirmed	[70]
2005-11-17	CVE-2005-3650 published in NVD; six Shadowcrew defendants plead guilty. Home: Four Books on Cybercrime	Vulnerability; Crime	Consumers; payments	Confirmed	[32][58][92]
2005-11-23	NIST SP 800-83, malware incident prevention and handling	Standards	Government	Confirmed	[71]
2005-12	RFC 4301, IPsec architecture; Solidus Networks (Pay By Touch) buys CardSystems' assets	Standards; Industry	Internet; payment processing	Confirmed	[76][16]

Date	Event	Thread	Sector	Grade	Sources
2005-12-01	FTC proposes the DSW consent order; NIST SP 800-77	Regulation; Standards	Retail; government	Confirmed	[12][13][72]
2005-12-13	MS05-055, the year's last Microsoft bulletin	Vulnerability	Technology	Confirmed	[40]
2005-12-28	The Windows Metafile flaw exploited before a patch: TA05-362A, VU#181038, Advisory 912840, CVE-2005-4560	Exploitation	Cross-sector	Confirmed	[34][35][37][36]
2005	The Zero Day Initiative established. Home: The Zero-Day Market; MITRE's PLOVER for NIST SAMATE; Illinois enacts its Personal Information Protection Act	Industry; Standards; Law	Cross-sector	Confirmed	[79][93][80][67]
2005	Snake operations under way; EQUATIONDRUG within its 2003 to 2013 development span	Espionage	Government	Inferred; Confirmed	[46][48]
2006-01-05 (boundary)	MS06-001 fixes the WMF flaw out of cycle	Vulnerability	Cross-sector	Confirmed	[38]
2006-01-26 (boundary)	ChoicePoint settles with the FTC	Regulation	Data broker	Confirmed	[4][6][7]
2006-02-23 (boundary)	CardSystems and Solidus settle with the FTC (final order 8 Sep 2006)	Regulation	Payment processing	Confirmed	[16]
2006-03-15 (boundary)	NIST tells agencies to stop using SHA-1 for digital signatures as soon as practical	Standards	Government	Confirmed	[82]
2006-05-08 (boundary)	Ancheta sentenced to 57 months	Crime	Government, consumers	Confirmed	[51]
2007-01-30 (boundary)	FTC settles with Sony BMG	Regulation	Consumers, media	Confirmed	[33]
2008-08-05 (boundary)	DOJ charges Albert Gonzalez and ten others over TJX, BJ's, DSW and other retailers. Home: E-Commerce Threats	Crime	Retail	Confirmed (as alleged)	[18][91]
2015-02 (boundary)	Kaspersky's Equation Q&A	Espionage	Unknown	Confirmed	[48]
2023-05-09 (boundary)	AA23-129A attributes Snake to FSB Center 16	Espionage	Government	Confirmed	[46]

Part 2: the data-broker and card-data breaches

ChoicePoint

ChoicePoint's 10-K says it found suspicious activity on 27 September 2004 by small-business customers in the Los Angeles area. They had opened accounts with stolen identities and altered documents and accessed names, addresses, Social Security numbers, driver's licence numbers and, in some cases, credit reports. About 145,000 consumers in all 50 states were notified. Class actions were filed on 18 and 22 February 2005, and the SEC opened an informal inquiry (Confirmed [1]).

The FTC's complaint gives the notice sequence. In February 2005, as a California law required, ChoicePoint notified about 35,000 California consumers that their information might have gone to people without a lawful purpose. Later notices to about 111,000 and then 17,000 more consumers brought the total to 163,000, and at least 800 identity-theft cases arose (Confirmed [5]). The FTC describes fraud by approved applicants, not a network intrusion. ChoicePoint approved applicants who lied about their credentials, used commercial mail drops and sent applications from public fax machines, and it did not monitor subscribers even after law-enforcement subpoenas between 2001 and 2005 flagged fraudulent accounts (Confirmed [6]; allegations).

The cost showed up in the filings. On 4 March 2005 ChoicePoint said it would stop selling certain sensitive consumer data products and estimated a $15 million to $20 million reduction in 2005 core revenue (Confirmed [2]). It took a $5.4 million pre-tax charge in the first quarter: about $2.0 million for notices and credit monitoring and $3.4 million for legal and professional fees (Confirmed [3]). On 26 January 2006 it settled *U.S. v. ChoicePoint* (FTC file 052-3069) for a $10 million civil penalty, which the FTC called the largest in its history, and $5 million in consumer redress. The case brought Fair Credit Reporting Act and FTC Act counts. The order requires credentialing and an independent security assessment every two years for 20 years (Confirmed [4][7]).

LexisNexis and Seisint

On 9 March 2005 Reed Elsevier said LexisNexis had found potentially fraudulent access to US consumer data at Seisint, a unit it had recently acquired, through the misappropriated IDs and passwords of legitimate customers (Confirmed [8]). On 12 April it reported 59 incidents over two years and about 310,000 US individuals whose names, addresses, Social Security numbers and driver's licence numbers might have been accessed, including the 30,000 notified in March. It stated that hackers had not breached its infrastructure (Confirmed [9]).

DSW Shoe Warehouse

Retail Ventures announced on 8 March 2005 that DSW had learned the week before of the theft of credit card and purchase data from customers of 103 stores, mostly from the previous three months, and that it had contacted federal law enforcement (Confirmed [10]). Its 18 April findings put the theft at 108 stores, with transaction data for 1.4 million cards (number, name and amount) and 96,000 checks (account and driver's licence numbers). Website and loyalty program data were not accessed (Confirmed [11]).

The FTC published a proposed consent order on 1 December 2005. It carried no fine but required a full security program and independent assessments every two years, with comments open to 2 January 2006 (Confirmed [12]). The FTC's release says DSW kept data it no longer needed, protected it with a commonly known user ID and password, did not limit access through wireless access points and did not separate its store networks. It puts the order's assessments at 20 years (Confirmed [13]; allegations).

BJ's Wholesale Club

On 16 June 2005 the FTC settled with BJ's (file 042-3160) on the theory that weak security was an unfair practice. BJ's did not encrypt card data, kept it for up to 30 days, left files reachable with commonly known default user IDs and passwords, and took no measures against unauthorized wireless connections. The result was millions of dollars in counterfeit-card purchases and about $13 million in outstanding claims as of May 2005. The order became final on 23 September 2005 (Confirmed [14]; allegations). The FTC pages opened here do not date the intrusion itself.

CardSystems Solutions

The FTC's complaint alleges that in September 2004 a hacker used SQL injection on CardSystems' web application to install common hacking programs. From November 2004 those programs collected magnetic-stripe data and sent it out of the network every four days. CardSystems stored the data for up to 30 days, and tens of millions of cards were exposed. In early 2005 issuing banks found several million dollars in counterfeit-card fraud (Confirmed [15]; allegations). Solidus Networks, doing business as Pay By Touch, bought CardSystems' assets in December 2005. On 23 February 2006 the FTC announced a settlement with both companies requiring a security program and independent audits every two years for 20 years. The failures it lists include not assessing exposure to SQL injection, weak passwords and poor intrusion detection, and the final order is dated 8 September 2006 (Confirmed [16]).

TJX and the Gonzalez ring (summary)

TJX's 10-K says an intruder first got into its systems in July 2005, came back on later dates in 2005 and again from mid-May 2006 to mid-January 2007, and that no data was stolen after 18 December 2006 (Confirmed [17]). On 5 August 2008 DOJ charged Albert Gonzalez and ten others with wardriving into the wireless networks of TJX, BJ's, OfficeMax, Boston Market, Barnes & Noble, Sports Authority, Forever 21 and DSW and installing sniffer programs on card-processing networks. More than 40 million card numbers were taken (Confirmed [18]; allegations). The charges tie two of 2005's FTC cases, BJ's and DSW, to the same ring (Inferred). E-Commerce Threats is the home for TJX and the Gonzalez case, and records about seventeen months from TJX's first access to discovery (Confirmed [91]).

Reading the year's breaches

ChoicePoint and LexisNexis/Seisint were abuses of legitimate access through fraudulent or misused customer accounts, not network intrusions. CardSystems, with SQL injection and scheduled exfiltration, and TJX, undetected from July 2005, were the year's deepest technical compromises of card data (Inferred [15][17]). Most of what the public learned came from the companies' own filings and the FTC's later orders, not from technical reports (Inferred).

Part 3: the vulnerability record

MS05-039 and the Plug and Play flaw

Microsoft's MS05-039 (9 August, KB 899588, Critical) fixed an unchecked buffer in the Plug and Play service, CAN-2005-1983, which Neel Mehta of ISS X-Force had reported privately (Confirmed [19]). Windows 2000 was mainly at risk from anonymous remote attack. On Windows XP SP1 only authenticated users could attack remotely, and on XP SP2 and Server 2003 the flaw was local only. The workaround was to block TCP 139 and 445 at the firewall, and Microsoft knew of no exploitation or proof of concept at release (Confirmed [19]). US-CERT's SA05-221A covered the month's bulletins and listed VU#998653 among five notes (Confirmed [20]).

CERT/CC's VU#998653 (first released 9 August, revised 15 November) says multiple exploit variants were public and that malware, including the Zotob worm, was actively exploiting the flaw. Zotob's in-the-wild code removes antivirus software and opens an IRC-controlled backdoor. The note adds that setting RestrictAnonymous to 2 reduces Windows 2000 exposure (Confirmed [21]). NVD published CVE-2005-1983 on 10 August as a stack-based buffer overflow "as exploited by the Zotob (aka Mytob) worm". It lists the weakness as NVD-CWE-Other, and the CVE has no KEV date (Confirmed [22]). Microsoft Security Advisory 899588 (11 August, updated 17 August) says Zotob targets Windows 2000 through the MS05-039 issue, that only a small number of customers were affected, and that Microsoft saw no sign of widespread Internet impact. It sent victims to the FBI and the Internet Fraud Complaint Center (Confirmed [23]).

VERITAS Backup Exec

NVD published CVE-2005-0773, a stack-based buffer overflow in the VERITAS Backup Exec Remote Agent, on 18 June. It lists NVD-CWE-Other, and the CVE has no KEV date (Confirmed [26]). On 29 June US-CERT's TA05-180A said the Remote Agent authentication flaw (VU#492105) was being actively exploited and that scanning on 10000/tcp had increased (Confirmed [25]). On 12 August TA05-224A reported that Backup Exec and NetBackup components used hard-coded administrative credentials over NDMP, allowing arbitrary files to be retrieved; Symantec's advisory is SYM05-011 (Confirmed [27]). Backup Exec and NetBackup agents, which hold copies of the data they back up, could be reached over NDMP with a hard-coded credential (Confirmed [27]; Inferred for the reading).

Cisco IOS IPv6

Cisco's advisory cisco-sa-20050729-ipv6 says a crafted IPv6 packet, sent from the local segment, could reload a device running IOS or IOS XR and might allow code execution. Only devices configured for IPv6 were affected. The flaw was disclosed on 27 July at the Black Hat conference; the advisory was first published on 29 July and went final on 11 August (Confirmed [28][29]). US-CERT's TA05-210A (VU#930892) noted the Black Hat disclosure (Confirmed [30]). No exploitation is recorded in these sources (Confirmed [28][30]).

Sony BMG's XCP

CERT/CC's VU#312073 says the First 4 Internet XCP DRM software on some Sony BMG audio CDs used rootkit technology to hide files. The ActiveX control used to uninstall it (CodeSupport.ocx) was marked safe for scripting and might let a web page download and run code (CVE-2005-3650) (Confirmed [31]). The note's public date is 15 November, and it was first released on 16 November (Confirmed [31]). NVD lists CWE-94 for CVE-2005-3650, published 17 November (Confirmed [32]). The FTC settled with Sony BMG on 30 January 2007 over software that installed itself without consent, hid itself, was hard to uninstall and created security vulnerabilities. Sony BMG had to exchange CDs, reimburse consumers up to $150 for damage from removal attempts, and provide uninstall tools and patches for two years (Confirmed [33]). Earlier public reporting on XCP was not checked.

The Windows Metafile flaw

On 28 December US-CERT's TA05-362A said the Windows Metafile flaw (VU#181038, CVE-2005-4560) was being exploited with public code against fully patched Windows XP SP2 and that no patch existed. The alert was revised on 29 December, when Microsoft published Security Advisory 912840, and again on 31 December (Confirmed [34][37]). CERT/CC's note (first released 28 December, revised 20 January 2006) calls it the SETABORTPROC GDI Escape vulnerability and says exploit code was posted publicly (Confirmed [35]). NVD published CVE-2005-4560 on 28 December with CWE-20 and notes the flaw was first found in the wild. It has no KEV date (Confirmed [36]). Microsoft shipped MS06-001 on 5 January 2006, ahead of the monthly cycle, and says the vulnerability was publicly disclosed and being exploited when it was issued (Confirmed [38]).

Microsoft's year and the CVE count

Microsoft's 2005 bulletins ran from MS05-001 on 11 January to MS05-055 on 13 December. MS05-056 and MS05-057 have no bulletin page (Confirmed [39][40]). That makes 55 bulletins for the year (Inferred). The NVD API returns 5,010 CVE records with an NVD publication date in calendar 2005, in four date windows of 719, 2,112, 1,722 and 457. This counts by NVD publication date, not by the CVE-2005 prefix (Confirmed [41]).

Part 4: worms, botnets and the web

Zotob and Mytob

On 26 August the FBI announced the arrests, on 25 August, of Farid Essebar, 18, in Morocco ("Diabl0") and Atilla Ekici, 21, in Turkey ("Coder") for the Mytob and Zotob worms. It said the worms had been released less than two weeks earlier and had disrupted the networks of companies including major US news organizations, and that Zotob exploits MS05-039. Moroccan police and the Turkish National Police made the arrests with help from Microsoft, and both men faced local prosecution (Confirmed [24]). The FBI's account of disruption and Microsoft's "small number of customers" are both primary records and do not agree on scale (Confirmed [24][23]). No ATT&CK software object exists for Zotob or Mytob (Demonstrated [85]).

Ancheta's botnets

On 3 November 2005 the FBI arrested Jeanson James Ancheta, 20, of Downey, California, on a 17-count indictment returned in the Central District of California on 2 November. DOJ called it the first prosecution of its kind (Confirmed [50]). The indictment alleges that he spread a modified rxbot trojan, sold access to IRC botnets of thousands of computers for DDoS attacks and spam, and installed adware on about 400,000 compromised computers for about $60,000 in affiliate payments. The bots included systems at the Naval Air Warfare Center Weapons Division at China Lake and at the Defense Information Systems Agency (Confirmed [50]; allegations). He pleaded guilty in January 2006 and was sentenced by Judge R. Gary Klausner to 57 months on 8 May 2006. He admitted about $3,000 from more than 30 botnet sales and more than $107,000 in adware proceeds from more than 400,000 computers (Confirmed [51]).

The Samy worm (author's account)

The author of the Samy cross-site scripting worm on MySpace says he released it around midday on 4 October 2005. It added him as a friend and "hero" on the profiles of people who viewed an infected page, and he says it reached more than 1,000,000 users in under 20 hours, after which MySpace went offline for maintenance at about 7:05 pm (Reported [42]). No vendor or court record behind these figures was opened (Reported [42]).

Sasser's author convicted

The BBC reported that Sven Jaschan was convicted in Germany of computer sabotage on 8 July 2005 for the Sasser worm of May 2004 and given a 21-month suspended sentence, tried as a minor (Reported [61]). The 2004 chronicle is the home for the worm and the arrest (Demonstrated [94]).

Part 5: the state record

TA05-189A: targeted trojan e-mail

US-CERT's Technical Alert TA05-189A of 8 July 2005 described e-mail sent to specific people that "appear to target US information for exfiltration", with emphasis on US critical-infrastructure networks (Confirmed [43]). The e-mails were socially engineered, used work-related subjects, and were spoofed to look as if they came from a colleague or trusted party. Attachments or links led to trojanized files that exploited known vulnerabilities. The trojans had been altered to evade antivirus and could use common ports such as TCP 80 to get past firewalls (Confirmed [43]). Once installed they could collect e-mail usernames and passwords, gather system information, scan network drives, upload documents and download more malware; the alert says trojan capabilities "suggest that exfiltration of data is a fundamental goal" (Confirmed [43]). It names no actor or state, does not mention the UK's NISCC, and says only that US-CERT worked with other CERTs (Confirmed [43]). No ATT&CK object maps the alert, so the technique rows in Part 9 are this study's mapping (Inferred [43][84]).

Titan Rain

Everything here is TIME's reporting of 29 August 2005 (Reported [44]). TIME said "Titan Rain" was federal investigators' code name for an espionage ring seeking export-controlled but not classified data. The activity was traced to three routers in Guangdong province and relayed through South Korea, Hong Kong and Taiwan. Named targets include Lockheed Martin (a September 2003 break-in), Sandia National Laboratories, Redstone Arsenal (the Army Aviation and Missile Command and FalconView 3.2), NASA (Mars Reconnaissance Orbiter schematics) and the World Bank (Reported [44]). TIME's timeline has a November 2003 Defense Department alert on hundreds of compromised systems, Sandia analyst Shawn Carpenter tracing the intruders from March 2004, his work handed to the FBI in October 2004, and alerts from Britain, Canada, Australia and New Zealand in June 2005 that referenced related activity (Reported [44]). Carpenter, who worked on his own time, was fired and lost his clearance. The FBI did not prosecute him, and he sued for defamation and wrongful termination (Reported [44]).

The attribution is hedged. Officials did not know whether the spying was official, a private-sector job or independent hackers; the FBI was looking into possible state involvement; and China's State Council Information Office called the charges "totally groundless" (Reported [44]). State attribution is not established. ATT&CK has no group object for Titan Rain (Demonstrated [85]). The 2003 chronicle and the 2004 chronicle carry the parts of TIME's account dated to those years, and this chronicle carries the 2005 alerts and the publication (Reported [44]; Demonstrated [94]).

The Athens wiretaps

IEEE Spectrum's "The Athens Affair" says the Vodafone Greece wiretap went undetected until 24 January 2005, when errors about undelivered text messages appeared. On 4 March Ericsson told Vodafone that unauthorized software was installed in two central offices, and Vodafone removed it in early March (Reported [45]). The rogue software, eventually found on four Ericsson AXE switches, abused the lawful-intercept subsystem while bypassing the interception management system, and hid itself like a rootkit. About 100 phones were tapped, including those of Prime Minister Karamanlis and the ministers of defense, foreign affairs and justice (Reported [45]). Costas Tsalikidis, Vodafone Greece's head of network planning, was found hanged on 9 March 2005, and the article says no connection to the wiretaps has been established (Reported [45]). On 10 March the Vodafone Greece CEO briefed the prime minister's office and five investigations followed. The perpetrator was never identified, and destroyed logs hampered the inquiries (Reported [45]). No ATT&CK object maps the operation, and this study binds none (Inferred).

Snake under way

The nine-agency advisory AA23-129A (9 May 2023) says the FSB began developing Snake as "Uroburos" in late 2003, finished the first versions around early 2004, and attributes Snake to a unit within Center 16 of the FSB (Confirmed [46]). The advisory says operations followed shortly thereafter. This study reads that as Snake being in use during 2005, though no 2005-dated victim is named (Inferred [46]). ATT&CK attributes Turla (G0010) to the FSB, says it "compromised victims in over 50 countries since at least 2004", and lists Uroburos (S0022), alias Snake, among its software (Confirmed [47]). The Russia study is the home.

Equation

Kaspersky's Equation Group Q&A (version 1.5, February 2015) says the group ran computer network exploitation operations "dating back to 2001, and perhaps as early as 1996", and names no sponsoring state (Confirmed [48]). It says the EQUATIONDRUG platform was developed from 2003 to 2013 (Confirmed [48]); this study reads that as the platform being current in 2005 (Inferred). It dates EQUATIONLASER to around 2001 to 2004 and records an EquationLaser installer sample compiled on 18 October 2004 (Confirmed [48]). ATT&CK's Equation (G0020) entry (version 1.2, modified 31 July 2026) names no sponsor and lists four techniques, none dated to 2005 (Confirmed [49]). The United States actors study is the home.

Part 6: crime and prosecutions

Phones, a data company and a juvenile

DOJ announced on 8 September 2005 that a Massachusetts juvenile had been sentenced to 11 months' detention for a 15-month spree that began in March 2004 (Confirmed [52]). It included an intrusion at an Internet service provider (August 2004); access to a telephone provider's systems and the online posting of a person's mobile phone data (January 2005); look-ups at a large identity-data company using an associate's accounts; bomb threats to schools; and a DDoS attack on a second telephone provider (June 2005). The release names no companies or victims, and this study names none (Confirmed [52]).

Other 2005 pleas and sentences

- **Jacobsen (15 February).** Nicholas Lee Jacobsen, 22, pleaded guilty in the Central District of California to intentionally accessing a protected computer and recklessly causing damage. His victims included T-Mobile, and the Secret Service had arrested him on 26 October 2004 (Confirmed [53]).
- **The RPCSDBOT juvenile (11 February).** A juvenile in the Western District of Washington was sentenced to three years of probation for releasing the RPCSDBOT worm in August 2003 and directing the 14 August 2003 DDoS that took Microsoft's main web site offline for about four hours (Confirmed [55]). The dot-com era study is the home for the 2003 worms, and the 2003 chronicle records the juvenile's arrest.
- **Jiang (28 February).** Juju Jiang was sentenced in the Southern District of New York to 27 months and $201,620 in restitution for installing keylogging software on Kinko's terminals in 2001 and 2002 (Confirmed [57]). The 2003 chronicle records his plea.
- **Lyttle (11 March).** Robert Lyttle of the "Deceptive Duo" pleaded guilty in the Northern District of California to five counts under 18 U.S.C. 1030 for April 2002 intrusions into federal agency systems and website defacements (Confirmed [56]).
- **Greco (21 March).** Anthony Greco, 18, pleaded guilty in the Central District of California to extortion threats against MySpace.com. His program had sent about 1.5 million spam messages in October and November 2004 (Confirmed [54]).

Operation Site Down

On 29 and 30 June the FBI and police in ten other countries carried out more than 90 searches, over 70 in the United States and over 20 abroad, against online piracy groups. Four people were arrested in the United States and at least eight major distribution sites were dismantled (Confirmed [60]).

Shadowcrew and Butler (summary)

DOJ announced on 17 November 2005 that six Shadowcrew defendants, Andrew Mantovani among them, had pleaded guilty in the District of New Jersey. Shadowcrew trafficked at least 1.5 million stolen card numbers with losses over $4 million, and 12 of the 21 people arrested in the United States had pleaded (Confirmed [58]). The 2007 indictment of Max Ray Butler ("Iceman") alleges that he hacked computers at financial institutions and card processing centers from about June 2005 (Confirmed [59]; allegation). Four Books on Cybercrime is the home for both, and also records a mid-2005 arrest in the *Fatal System Error* case, which that study grades Reported (Confirmed [92]).

Part 7: law, regulation and standards

Breach notice and the banks

- **Interagency guidance (29 March).** The OCC, the Federal Reserve Board, the FDIC and the OTS published the Interagency Guidance on Response Programs for Unauthorized Access to Customer Information and Customer Notice (70 FR 15736) as an interpretation of the Gramm-Leach-Bliley Act and the interagency security guidelines (Confirmed [63]).
- **OCC Bulletin 2005-13 (14 April).** Every bank should have a breach response program. It should notify customers as soon as possible when misuse has happened or is reasonably possible, may delay on a written law-enforcement request, and should notify its primary federal regulator (Confirmed [64]).
- **FFIEC authentication guidance (12 October).** Authentication in an Internet Banking Environment (FDIC FIL-103-2005) says single-factor authentication may not be enough for internet banking and expects banks to comply by the end of 2006 (Confirmed [65]).
- **State law.** ChoicePoint's first notices went to California consumers because of a California requirement (Confirmed [5]). Illinois enacted its Personal Information Protection Act (815 ILCS 530) as Public Act 94-36, effective 1 January 2006, making violations unlawful practices under the state's Consumer Fraud Act (Confirmed [67]). It is one example of the year's state breach-notice laws; the total count was not checked.

The FTC as a security regulator

The FTC's 2005 and early 2006 cases (BJ's in June, DSW in December, ChoicePoint in January, CardSystems in February) all rest on the theory that inadequate security can be an unfair practice. The DSW, ChoicePoint and CardSystems orders impose a security program with independent assessments every two years for 20 years (Confirmed [13][7][16]); the BJ's order's terms were not checked here. ChoicePoint's is the only one in these sources with a civil penalty (Confirmed [14][13][7][16]). These orders became the model remedy (Inferred).

Federal policy

- **GAO-05-231 (13 May, released 13 June).** Emerging Cybersecurity Issues Threaten Federal Information Systems addressed spam, phishing and spyware and recommended OMB guidance. GAO closed both recommendations in July 2006 (Confirmed [62]).
- **Energy Policy Act of 2005 (8 August).** Section 1211 of Public Law 109-58 created mandatory bulk-power reliability standards enforced by an Electric Reliability Organization that FERC certifies. In the Act a

reliability standard includes requirements for "cybersecurity protection", and reliable operation includes withstanding a "cybersecurity incident" (Confirmed [66]). This is the statutory root of the later NERC CIP regime; the CIP standards themselves were not checked. The industrial thread runs on through Stuxnet, the ICS attacks and advisories study and the ICS ATT&CK Atlas (Inferred).

NIST

- **FIPS 201 (25 February).** Personal Identity Verification of Federal Employees and Contractors (Confirmed [69]).
- **SP 800-53 (28 February).** Recommended Security Controls for Federal Information Systems, the first federal control catalog. It was withdrawn on 22 April 2005 and replaced by an updated release (Confirmed [68]).
- **SP 800-40 Version 2 (16 November).** Creating a Patch and Vulnerability Management Program, superseding the 2002 version 1; withdrawn in 2013 (Confirmed [70]).
- **SP 800-83 (23 November).** Guide to Malware Incident Prevention and Handling; withdrawn in 2013 and superseded by Revision 1 (Confirmed [71]).
- **SP 800-77 (1 December).** Guide to IPsec VPNs (Confirmed [72]).
- **SHA-1, just after the year.** On 15 March 2006 NIST told agencies to stop using SHA-1 for digital signatures as soon as practical and to use SHA-2 after 2010. The policy page does not mention the 2005 collision research, and no primary for that research was opened (Confirmed [82]).

ISO and the IETF

- **ISO/IEC 17799:2005 (10 June).** The code of practice for information security management, edition 2; later revised as ISO/IEC 27002:2005 and withdrawn on 3 June 2010 (Confirmed [73]).
- **ISO/IEC 27001:2005 (14 October).** ISMS requirements, edition 1; withdrawn on 25 September 2013 and revised by ISO/IEC 27001:2013 (Confirmed [74]).
- **RFC 4033 (March).** DNS Security Introduction and Requirements (DNSSEC-bis), Standards Track; it obsoletes RFC 2535 and eight other RFCs (Confirmed [75]).
- **RFC 4301 (December).** Security Architecture for the Internet Protocol, obsoleting RFC 2401 (Confirmed [76]).

The vendor and research side

- **The SDL paper (March).** Microsoft's Lipner and Howard published an updated "The Trustworthy Computing Security Development Lifecycle". It covers threat modeling, static analysis with PREfix and PREfast, fuzz testing, the security push and the Final Security Review, and says the SDL was becoming mandatory for networked, enterprise and personal-data software (Confirmed [77]). The dot-com era study is the home for the SDL's start.
- **CVSS (14 April).** The National Infrastructure Advisory Council chose FIRST as the custodian of CVSS, which it called the emerging standard in vulnerability scoring. The CVSS v1 page does not give v1's publication date (Confirmed [78]).

- **The Zero Day Initiative (2005).** ZDI says it was set up in 2005 so that researchers would report zero-days privately to vendors (Confirmed [79]). The Zero-Day Market is the home (Confirmed [93]).
- **PLOVER (2005).** MITRE produced PLOVER for the DHS-sponsored NIST SAMATE project: more than 1,500 real-world vulnerability examples under 290 weakness types, the groundwork for the first CWE List in 2006 (Confirmed [80]).

Part 8: the defender view

The breach was often an account, not an exploit. ChoicePoint and LexisNexis lost data through customer accounts, and the Massachusetts juvenile used an associate's accounts at an identity-data company (Confirmed [6][9][52]). The controls that mattered were customer vetting, query monitoring and credential hygiene, which the ChoicePoint order's credentialing obligation reflects (Confirmed [4]; Inferred for the reading).

Retention made the losses bigger. BJ's and CardSystems each kept card data for up to 30 days, and DSW kept data it no longer needed (Confirmed [14][15][13]). Data that had been deleted could not have been stolen (Inferred).

Defaults and shared secrets were the common weakness. The FTC cites default or commonly known credentials at BJ's and DSW, weak passwords at CardSystems, and US-CERT cites hard-coded credentials in VERITAS products (Confirmed [14][13][16][27]). The identity and access management reference covers what replaced them.

The web application was the door at the processor. The FTC's CardSystems order names the failure to assess SQL injection exposure (Confirmed [16]). The web application security reference and database security reference cover the defenses.

Detection lagged by months. CardSystems' exfiltration ran from November 2004 until issuers found fraud in early 2005, and TJX's intruder had access from July 2005 until TJX found suspicious software on 18 December 2006, with access continuing to mid-January 2007 (Confirmed [15][17][91]). CardSystems' breach was found from outside, through issuers' counterfeit fraud; TJX's took about seventeen months to find (Inferred).

Patch time was short, and once there was no patch. Zotob followed MS05-039 within days, the VERITAS flaw was under active exploitation eleven days after its NVD record, and the WMF flaw was exploited before any fix (Confirmed [19][24][26][25][34]; Inferred for the intervals). The Log4Shell study shows the same pattern at larger scale, and the vulnerability management reference covers the program NIST's SP 800-40 v2 described in November (Confirmed [70]; Inferred).

The vendor's own software became the risk. XCP hid itself and shipped an unsafe uninstaller, and VERITAS shipped fixed credentials (Confirmed [31][27]). The supply chain security reference and the SolarWinds study follow trusted-software risk into later years (Inferred).

Regulation started to prescribe controls. The FFIEC's authentication guidance, the interagency notice standard and the FTC's 20-year orders turned security failures into compliance obligations (Confirmed [65][63][14]). The GRC and compliance reference covers the frameworks that followed ISO/IEC 27001:2005 and SP 800-53 (Confirmed [74][68]).

Part 9: MITRE mappings

No 2005 record carries an ATT&CK, CWE or CAPEC id from the time. PLOVER was the only weakness catalog of 2005, the first CWE List came in 2006 and CAPEC in 2007 (Confirmed [80][81]). Every Enterprise binding below is this study's later mapping (Inferred), apart from the objects ATT&CK itself dates to the period (Confirmed [47][49]). Every id was checked against the library's data files and the generated pages under `mitre/`, and every technique below is live in the library's release data (Demonstrated [83][84][85][86][89]). Names and tactics are those of ATT&CK v20.0 as the library carries them.

The Basis column says how strong each tie is, as in the 2016 chronicle. **Listed** means ATT&CK itself lists the id for the event or object. **Described** means a primary source describes the behavior and this study assigns the id. **Reported** means only a secondary source supports the behavior. **Inferred** means no source describes the behavior in enough detail and the mapping rests on this study's reading.

ATT&CK Enterprise techniques

Id	Name (ATT&CK v20.0)	Tactic(s)	Basis	Dated event or report	Sources
T1190	Exploit Public-Facing Application	initial-access	Described	CardSystems' web application compromised by SQL injection (Sep 2004; FTC complaint)	[15][16]
T1005	Data from Local System	collection	Described	CardSystems: installed programs collect stored magnetic-stripe data (from Nov 2004)	[15]
T1029	Scheduled Transfer	exfiltration	Described	CardSystems: data sent out of the network every four days (from Nov 2004)	[15]
T1078	Valid Accounts	stealth, persistence, privilege-escalation, initial-access	Described	LexisNexis/Seisint: misappropriated IDs and passwords of legitimate customers (9 Mar, 12 Apr); the Massachusetts juvenile's look-ups through an associate's accounts (sentenced 8 Sep)	[8][9][52]
T1078.001	Default Accounts	stealth, persistence, privilege-escalation, initial-access	Described	BJ's commonly known default user IDs and passwords (16 Jun); DSW's commonly known user ID and password (1 Dec)	[14][13]
T1669	Wi-Fi Networks	initial-access	Described	The Gonzalez ring's wardriving into BJ's, DSW and other retailers (charged 5 Aug 2008, alleged); BJ's and DSW wireless failures (2005)	[18][14][13]
T1040	Network Sniffing	credential-access, discovery	Described	Sniffer programs on card-processing networks (charged 5 Aug 2008, alleged)	[18]
T1210	Exploitation of Remote Services	lateral-movement	Described	Zotob exploiting CVE-2005-1983 (Aug)	[21][22][23][24]
T1685	Disable or Modify Tools	defense-impairment	Described	Zotob's in-the-wild code removes antivirus software (VU#998653). T1562.001 is revoked and superseded by T1685	[21][86]
T1071	Application Layer Protocol	command-and-control	Described	Zotob opens an IRC-controlled backdoor (VU#998653); Ancheta's IRC botnets (3 Nov)	[21][50]
T1068	Exploitation for Privilege Escalation	privilege-escalation	Inferred	MS05-039's local elevation of privilege on XP SP2 and Server 2003; a property of the flaw, not observed use	[19]
T1203	Exploitation for Client Execution	execution	Described	The WMF flaw exploited against patched XP SP2 (28 Dec); TA05-189A's trojanized files exploiting known flaws (8 Jul)	[34][35][43]

Id	Name (ATT&CK v20.0)	Tactic(s)	Basis	Dated event or report	Sources
T1189	Drive-by Compromise	initial-access	Inferred	The WMF flaw's likely delivery through web content (28 Dec); not stated in the sources	[34][35]
T1584.005	Botnet	resource-development	Described	Ancheta's botnets of thousands of computers, sold for DDoS and spam (3 Nov, alleged)	[50][51]
T1498	Network Denial of Service	impact	Described	Ancheta's DDoS sales (3 Nov, alleged); the Massachusetts juvenile's DDoS on a telephone provider (Jun 2005); the RPCSDBOT DDoS (14 Aug 2003, sentenced 11 Feb 2005)	[50][52][55]
T1014	Rootkit	stealth	Described	Sony BMG's XCP uses rootkit technology to hide files (VU#312073, Nov)	[31]
T1564.001	Hidden Files and Directories	stealth	Described	XCP hides its files (Nov)	[31]
T1056.001	Keylogging	collection, credential-access	Described	Jiang's keylogging software on Kinko's terminals (2001 to 2002; sentenced 28 Feb 2005)	[57]
T1491.002	External Defacement	impact	Described	The Deceptive Duo's website defacements (Apr 2002; plea 11 Mar 2005)	[56]
T1059.007	JavaScript	execution	Reported	The Samy cross-site scripting worm (4 Oct, author's account)	[42]
T1566.001	Spearphishing Attachment	initial-access	Described	TA05-189A: spoofed, work-themed e-mail with trojanized attachments (8 Jul)	[43]
T1566.002	Spearphishing Link	initial-access	Described	TA05-189A: links to trojanized files (8 Jul)	[43]
T1204.002	Malicious File	execution	Described	TA05-189A: socially engineered recipients open the files (8 Jul)	[43]
T1027	Obfuscated Files or Information	stealth	Inferred	TA05-189A: trojans altered to evade antivirus; the alteration method is not stated (8 Jul)	[43]
T1071.001	Web Protocols	command-and-control	Described	TA05-189A: trojans use common ports such as TCP 80 to pass firewalls (8 Jul)	[43]
T1082	System Information Discovery	discovery	Described	TA05-189A: trojans gather system information (8 Jul)	[43]
T1135	Network Share Discovery	discovery	Described	TA05-189A: trojans scan network drives (8 Jul)	[43]

Id	Name (ATT&CK v20.0)	Tactic(s)	Basis	Dated event or report	Sources
T1039	Data from Network Shared Drive	collection	Inferred	TA05-189A: network-drive scanning and document upload; the alert does not say the uploaded documents came from the drives (8 Jul)	[43]
T1105	Ingress Tool Transfer	command-and-control	Described	TA05-189A: trojans download more malware (8 Jul)	[43]
T1041	Exfiltration Over C2 Channel	exfiltration	Described	TA05-189A: trojans upload documents; the alert says their capabilities suggest exfiltration is a fundamental goal (8 Jul)	[43]
T1046	Network Service Discovery	discovery	Described	TA05-180A: increased scanning on 10000/tcp for the VERITAS Remote Agent (29 Jun)	[25]

Left out on purpose: an exploitation technique for the VERITAS flaw, because TA05-180A does not say whether the exploited agents faced the Internet or were reached from inside, so T1190 and T1210 cannot be chosen between (Confirmed [25]; Inferred). Credential theft from e-mail clients in TA05-189A, because the alert does not say how the usernames and passwords were collected (Confirmed [43]). T1189 for XCP's uninstaller, because no in-the-wild use was checked (Confirmed [31]; Inferred). ChoicePoint's fraudulent account openings, because applying for a data broker's service with stolen identities is not an ATT&CK technique as the library carries them (Confirmed [6]; Inferred). The Cisco IPv6 flaw, which no source records as exploited (Confirmed [28][30]). Titan Rain and the Athens wiretaps, which no ATT&CK object covers and whose only sources are Reported (Reported [44][45]).

Techniques ATT&CK lists for objects it dates to the period

ATT&CK draws these from later analyses, not from a dated 2005 event, so they are not in this study's Navigator layer (Confirmed [49]; Inferred).

Id	Name (ATT&CK v20.0)	Tactic(s)	Object	Basis	Sources
T1480.001	Environmental Keying	stealth	G0020 Equation	Listed (group)	[49][84]
T1564.005	Hidden File System	stealth	G0020 Equation	Listed (group)	[49][84]
T1120	Peripheral Device Discovery	discovery	G0020 Equation	Listed (group)	[49][84]
T1542.002	Component Firmware	stealth, persistence	G0020 Equation	Listed (group)	[49][84]

Snake's technique list in AA23-129A describes the implant as analysed in 2023. The Russia study carries it, and this study presents none of it as observed in 2005 (Inferred [46]).

ATT&CK for ICS

No 2005 event in the record opened here touches an industrial control system. The Energy Policy Act's reliability provisions are law about the grid, not an intrusion (Confirmed [66]). This study therefore has no ATT&CK for ICS table and no ICS layer (Inferred).

ATT&CK groups, software and campaigns

Object	Id	Binding	Sources
Turla	G0010	Bound with a caveat: AA23-129A puts Snake's first operations shortly after early 2004, and ATT&CK dates victims since at least 2004; no 2005-dated victim is named	[46][47]
Uroburos (Snake)	S0022	Bound with a caveat: in use during 2005 by this study's reading of AA23-129A	[46][47][85]
Equation	G0020	Bound with a caveat: EQUATIONDRUG developed from 2003 to 2013; no 2005-dated event; no state named	[48][49]

No campaign object is bound. The library's software data has no ATT&CK object for Zotob, Mytob, rxbot, Samy or XCP, and no group object for Titan Rain (Demonstrated [85]).

CWE and CAPEC

NVD's CWE ids for these CVEs can only have been assigned after the CWE List's first release in 2006 (Confirmed [80]; Inferred for the assignment dates). Rows marked NVD carry the CWE NVD lists; the others are this study's classes (Inferred). Names are those in the library's CWE and CAPEC data, and every CAPEC listed has a page under `/mitre/capec/` (Demonstrated [88][89]). The library has no per-CWE generated pages, so CWE ids are plain text; the CWE reference is the library's entry point (Demonstrated [89]).

CWE	Weakness (library name)	Basis	2005 record	CAPEC
CWE-20	Improper Input Validation	NVD	Windows Metafile (CVE-2005-4560)	None assigned
CWE-94	Improper Control of Generation of Code	NVD	XCP's CodeSupport ActiveX control (CVE-2005-3650)	CAPEC-242 Code Injection (this study's pairing)
NVD-CWE-Other	(as NVD lists it)	NVD	Plug and Play (CVE-2005-1983); VERITAS Remote Agent (CVE-2005-0773)	See CWE-121
CWE-121	Stack-based Buffer Overflow	Study's class	Plug and Play and VERITAS, which NVD describes as stack-based overflows	CAPEC-100 Overflow Buffers
CWE-89	Improper Neutralization of Special Elements used in an SQL Command	Study's class	CardSystems (FTC complaint)	CAPEC-66 SQL Injection
CWE-1392	Use of Default Credentials	Study's class	BJ's and DSW (FTC)	CAPEC-70 Try Common or Default Usernames and Passwords (the library lists it on T1078.001)
CWE-798	Use of Hard-coded Credentials	Study's class	VERITAS NDMP credentials (TA05-224A)	CAPEC-70 (this study's pairing)
CWE-311	Missing Encryption of Sensitive Data	Study's class	BJ's unencrypted card data (FTC)	None assigned

CWE	Weakness (library name)	Basis	2005 record	CAPEC
CWE-79	Improper Neutralization of Input During Web Page Generation	Study's class	The Samy worm (Reported)	CAPEC-63 Cross-Site Scripting (XSS)
CWE-749 and CWE-912	Exposed Dangerous Method or Function; Hidden Functionality	Study's class	XCP's safe-for-scripting uninstaller and self-hiding files	CAPEC-552 Install Rootkit (the library lists it on T1014)
none bound	(credentials)	Library data	LexisNexis misused customer credentials	CAPEC-560 Use of Known Domain Credentials (the library lists it on T1078)
none bound	(sniffing)	Library data	The Gonzalez ring's sniffers (alleged)	CAPEC-158 Sniffing Network Traffic (the library lists it on T1040)
none bound	(keylogging)	Library data	Jiang's Kinko's keylogger	CAPEC-568 Capture Credentials via Keylogger (the library lists it on T1056.001)
none bound	(phishing)	Library data	TA05-189A e-mail	CAPEC-163 Spear Phishing (the library lists it on T1566.001 and T1566.002)
none bound	(scanning)	Library data	Scanning on 10000/tcp	CAPEC-300 Port Scanning (the library lists it on T1046)
none bound	(security tools removed)	Library data	Zotob removing antivirus	CAPEC-578 Disable Security Software (the library lists it on T1685)
none bound	(downloads)	Study's pairing	TA05-189A trojans downloading more malware	CAPEC-185 Malicious Software Download
none bound	(flooding)	Study's pairing	Ancheta's and the juveniles' DDoS	CAPEC-125 Flooding

D3FEND countermeasures

The technique-to-countermeasure links come from the library's D3FEND data unless the row says the pairing is this study's; pairing them with the 2005 advice is this study's reading (Confirmed [87]; Inferred). Every page exists under `/mitre/d3fend/` (Demonstrated [89]).

Technique from the record	D3FEND countermeasures	2005 analogue
T1190	Database Query String Analysis (D3-DQSA); Inbound Traffic Filtering (D3-ITF)	The SQL injection assessment the FTC says CardSystems never did [16]
T1190, T1210, T1189	Network Traffic Filtering (D3-NTF)	MS05-039's workaround: block TCP 139 and 445 at the firewall [19]
T1210, T1068, T1203	Stack Frame Canary Validation (D3-SFCV); Segment Address Offset Randomization (D3-SAOR); Process Segment Execution Prevention (D3-PSEP)	Memory protections against the year's stack overflows; not the 2005 advice, which was patch and block (Inferred) [19][26]

Technique from the record	D3FEND countermeasures	2005 analogue
T1210	Connection Attempt Analysis (D3-CAA)	Watching for worm scanning on the ports MS05-039 named [19]
T1029, T1041	Per Host Download-Upload Ratio Analysis (D3-PHDURA)	CardSystems' scheduled exfiltration; TA05-189A's document uploads [15][43]
T1071.001	Outbound Traffic Filtering (D3-OTF)	TA05-189A's trojans using TCP 80 to pass firewalls [43]
T1078, T1078.001	Change Default Password (D3-CDP); User Account Permissions (D3-UAP); Account Locking (D3-AL)	BJ's and DSW default credentials; LexisNexis's misused customer IDs [14][13][9]
T1566.001, T1566.002	Email Filtering (D3-EF); Sender Reputation Analysis (D3-SRA); URL Analysis (D3-UA, T1566.002)	TA05-189A's spoofed e-mail and links [43]
T1204.002	Executable Allowlisting (D3-EAL); File Analysis (D3-FA)	Trojanized attachments altered to evade antivirus [43]
T1189	URL Reputation Analysis (D3-URA)	The WMF exposure through web content (Inferred) [34]
T1014	Software Update (D3-SU); File Analysis (D3-FA); Content Filtering (D3-CF); Software Inventory (D3-SWI)	Removing XCP and patching its uninstaller [31][33]
T1056.001	Input Device Analysis (D3-IDA)	Jiang's keylogging software on shared terminals [57]

The library links T1669, T1498, T1685, T1584.005, T1564.001 and T1059.007 to no D3FEND countermeasure, and T1040 only to DNS Traffic Analysis, which has no 2005 analogue here (Demonstrated [87]). ATT&CK mitigation pages exist for M1051 Update Software, M1037 Filter Network Traffic, M1027 Password Policies, M1041 Encrypt Sensitive Information, M1030 Network Segmentation, M1032 Multi-factor Authentication, M1049 Antivirus/Antimalware, M1050 Exploit Protection and M1017 User Training (Demonstrated [89]). The FTC's orders map most closely to M1027, M1041 and M1030, and the FFIEC guidance to M1032 (Inferred [14][13][65]).

Navigator layer

The study's Enterprise techniques are saved as one ATT&CK Navigator layer pinned to ATT&CK v20, navigator/library-layers/chronicle-2005.json, in the format of the existing chronicle layers: domain enterprise-attack, navigator 4.9, layer 4.5, described as a curated case-study layer and not an official MITRE mapping (Demonstrated [90]). It lists the 31 techniques in the Enterprise table under each tactic they carry in v20.0 and is listed on the Navigator layers page. The Equation techniques in the second table are not in it. Scores show the basis, not severity, in the house scale set by the 2016 chronicle: 100 where the source or ATT&CK prints the id, 70 where a primary source describes the behavior and this study assigns the id, 50 where only a Reported source supports it, and 40 for an Inferred mapping (Demonstrated [90]). No 2005 source prints an ATT&CK id, so no technique scores 100. T1059.007 scores 50; T1068, T1189, T1027 and T1039 score 40; every other row scores 70 (Inferred). Each entry's comment names the source numbers in the Sources table below. No ICS layer is needed (Inferred).

Cross-cutting themes

Personal data became the thing to steal. The year's headline losses were Social Security numbers and card numbers, from a data broker, an information service, a shoe retailer, a warehouse club and a processor (Confirmed [1][9][11][14][15]). In 2005 the breach changed from something that happened to the company into something that happened to customers (Inferred).

Disclosure law made the breaches visible. ChoicePoint's first notices went out because California required them, the bank regulators wrote a notice standard in March and April, and Illinois followed with its own law (Confirmed [5][63][64][67]). Most of the year's breach record exists because someone was required to send a letter (Inferred).

The FTC wrote the security standard by settlement. DSW, ChoicePoint and CardSystems each received a 20-year order with biennial assessments, and BJ's an order on the same unfairness theory, all built on the idea that inadequate security is unfair (Confirmed [14][13][7][16]).

Attackers used valid access as often as exploits. Customer accounts at the brokers, default passwords at the retailers, hard-coded credentials in backup software and an associate's accounts at an identity-data company all show up in 2005 (Confirmed [6][9][14][13][27][52]).

Worm and botnet operators were charged quickly; espionage stayed in the shadows. The Zotob suspects were arrested less than two weeks after the FBI says the worms were released, and Ancheta was indicted and arrested in November, while Titan Rain, the Athens wiretaps, Snake and Equation were either reported without attribution or documented years later (Confirmed [24][50][46][48]; Reported [44][45]).

The plumbing of later security work was laid down. SP 800-53, FIPS 201, ISO/IEC 27001, CVSS's custodian, PLOVER, ZDI, SP 800-40 v2, DNSSEC-bis and RFC 4301 all date from 2005 (Confirmed [68][69][74][78][80][79][70][75][76]).

What is overstated and what is understated

This section is the study's reading of the record (Inferred).

- **Overstated: ChoicePoint and LexisNexis as hacks.** Both were fraud through approved or misused accounts: the FTC describes approved fraudulent applicants, and LexisNexis said its infrastructure was not breached [6][9].
- **Overstated: Zotob as an Internet-scale worm.** The FBI says it disrupted networks at companies including major news organizations, but Microsoft's advisory says only a small number of customers were affected and the remote exposure was mainly Windows 2000 [24][23][19].
- **Overstated: MS05-039 as a flaw in every Windows version.** On XP SP2 and Server 2003 it was local only [19].
- **Overstated: the 2005 standards wave as a turning point.** ISO/IEC 27001, SP 800-53 and the SDL paper read as a break with the past, but none of the sources opened here shows how quickly they were adopted; the original SP 800-53 was replaced within eight weeks [74][68][77].
- **Overstated: Titan Rain as a confirmed Chinese government operation.** TIME's sources traced it to routers in Guangdong and said they did not know whether the spying was official [44].

- **Overstated: the Samy worm's figures.** The million-user count comes only from the author's own account [42].
- **Overstated: round breach counts.** ChoicePoint's total is 145,000 in its 10-K and 163,000 in the FTC complaint; DSW's affected stores are 103, then 108; and CardSystems' exposure is "tens of millions" without a checked figure [1][5][10][11][15].
- **Overstated: the precision of ids on 2005 events.** Every ATT&CK and CAPEC id and most CWE ids here are retrospective, and NVD gives a specific CWE for only two of the four 2005 CVEs checked [80][81][22][26][32][36].
- **Understated: the processor as the weak point.** One card processor's SQL injection exposed tens of millions of cards, far more than DSW's 1.4 million cards [15][11].
- **Understated: retention.** BJ's and CardSystems kept data for up to 30 days and DSW kept data it no longer needed; the loss scaled with what was kept [14][15][13].
- **Understated: backup software as attack surface.** VERITAS had an actively exploited overflow and hard-coded credentials in the same year [25][27].
- **Understated: TA05-189A.** A government alert described targeted e-mail trojans aimed at US information, and urged government and critical-infrastructure operators to act, in July 2005, with less public attention than the year's worms [43].
- **Understated: Snake's operating start.** A nine-agency government record puts Snake's first operations in the period, a stronger record than anything published in 2005 itself [46].
- **Understated: the vendor-side work.** The SDL, ZDI, CVSS custody, DNSSEC-bis, RFC 4301 and SP 800-40 v2's patch programs get one line each against many for the breaches, yet later records rely on them [77][79][78][75][76][70].
- **Understated: defender cost.** Apart from ChoicePoint's $5.4 million charge and its $15 million to $20 million revenue estimate, no primary opened here puts a figure on remediation [3][2].

Discrepancies in the record

- **ChoicePoint's total.** About 145,000 consumers in all 50 states in the 10-K; 163,000 in the FTC complaint, built from notices to about 35,000, 111,000 and 17,000 [1][5].
- **DSW's stores.** 103 stores in the 8 March announcement and 108 in the 18 April findings [10][11]. The FTC's release refers to about 190 stores in 32 states; the sources opened do not settle whether that counts affected stores or the chain, and this study does not resolve it [13].
- **Ancheta's adware money.** About $60,000 in the arrest release; more than $107,000 admitted at sentencing [50][51].
- **VU#312073's date.** A public date of 15 November and a first release on 16 November [31].
- **The Zotob arrests.** Made on 25 August, announced by the FBI on 26 August [24].
- **Zotob's impact.** Disruption at companies including major US news organizations (FBI) against a small number of customers and no widespread Internet impact (Microsoft) [24][23].
- **The original SP 800-53.** Final on 28 February 2005, withdrawn on 22 April 2005 [68].
- **The Cisco IPv6 advisory.** Disclosed at Black Hat on 27 July, first published 29 July, final 11 August [28].
- **ISO/IEC 17799:2005.** Revised as ISO/IEC 27002:2005 and withdrawn on 3 June 2010 [73].

Sources

Sources were opened on 12 or 13 November 2026 as the Opened column shows, and the library data checks were run on 13 November 2026. All are checked as of 13 November 2026. Grade is the source's evidence grade as used in this study. Addresses shown as code rather than as links refuse automated link checkers (the sec.gov filings, the ftc.gov pages, the gao.gov page, the Illinois General Assembly page, the cisco.com copy of the IPv6 advisory and the NVD API queries); copy them into a browser to open them.

#	Source	URL	Opened	Grade
1	ChoicePoint Inc., Form 10-K for fiscal 2004 (SEC EDGAR)	`https://www.sec.gov/Archives/edgar/data/1040596/000095014405002577/g93507e10vk.htm`	2026-11-12	Confirmed
2	ChoicePoint Inc., Form 8-K, 4 Mar 2005 (SEC EDGAR)	`https://www.sec.gov/Archives/edgar/data/1040596/000095014405002087/g93611e8vk.htm`	2026-11-12	Confirmed
3	ChoicePoint Inc., Form 10-Q, first quarter 2005 (SEC EDGAR)	`https://www.sec.gov/Archives/edgar/data/1040596/000095014405005205/g95170e10vq.htm`	2026-11-12	Confirmed
4	ChoicePoint Inc., Form 8-K on the FTC settlement, Jan 2006 (SEC EDGAR)	`https://www.sec.gov/Archives/edgar/data/1040596/000095014406000610/g99324e8vk.htm`	2026-11-12	Confirmed
5	FTC, complaint in U.S. v. ChoicePoint	`https://www.ftc.gov/sites/default/files/documents/cases/2006/01/0523069complaint.pdf`	2026-11-13	Confirmed
6	FTC, "ChoicePoint Settles Data Security Breach Charges", Jan 2006	`https://www.ftc.gov/news-events/news/press-releases/2006/01/choicepoint-settles-data-security-breach-charges-pay-10-million-civil-penalties-5-million-consumer`	2026-11-13	Confirmed
7	FTC, case page 052-3069, ChoicePoint Inc.	`https://www.ftc.gov/legal-library/browse/cases-proceedings/052-3069-choicepoint-inc`	2026-11-13	Confirmed
8	Reed Elsevier, Form 6-K, 9 Mar 2005 (SEC EDGAR)	`https://www.sec.gov/Archives/edgar/data/929869/000115697305000286/u48441e6vk.htm`	2026-11-12	Confirmed
9	Reed Elsevier, Form 6-K, 12 Apr 2005 (SEC EDGAR)	`https://www.sec.gov/Archives/edgar/data/929869/000115697305000453/u48589e6vk.htm`	2026-11-12	Confirmed
10	Retail Ventures, Exhibit 99.1, 8 Mar 2005 (SEC EDGAR)	`https://www.sec.gov/Archives/edgar/data/874444/000095015205001902/l12722aexv99w1.txt`	2026-11-12	Confirmed
11	Retail Ventures, Exhibit 99.1, 18 Apr 2005 (SEC EDGAR)	`https://www.sec.gov/Archives/edgar/data/874444/000095015205003255/l13423aexv99w1.htm`	2026-11-12	Confirmed
12	DSW Inc., Form 10-Q (FTC proposed consent order), Dec 2005 (SEC EDGAR)	`https://www.sec.gov/Archives/edgar/data/1319947/000095015205009821/l17332ae10vq.htm`	2026-11-12	Confirmed
13	FTC, "DSW Inc. Settles FTC Charges", 1 Dec 2005	`https://www.ftc.gov/news-events/news/press-releases/2005/12/dsw-inc-settles-ftc-charges`	2026-11-13	Confirmed
14	FTC, "BJ's Wholesale Club Settles FTC Charges", 16 Jun 2005	`https://www.ftc.gov/news-events/news/press-releases/2005/06/bjs-wholesale-club-settles-ftc-charges`	2026-11-13	Confirmed

#	Source	URL	Opened	Grade
15	FTC, complaint in In the Matter of CardSystems Solutions	https://www.ftc.gov/sites/default/files/documents/cases/2006/02/0523148complaint.pdf	2026-11-12, 2026-11-13	Confirmed; Inferred (the lens reading in Part 2)
16	FTC, "CardSystems Solutions Settles FTC Charges", 23 Feb 2006	https://www.ftc.gov/news-events/news/press-releases/2006/02/cardsystems-solutions-settles-ftc-charges	2026-11-12, 2026-11-13	Confirmed
17	The TJX Companies, Form 10-K for fiscal 2007 (SEC EDGAR)	https://www.sec.gov/Archives/edgar/data/109198/000095013507001906/b64407tje10vk.htm	2026-11-12, 2026-11-13	Confirmed
18	DOJ, charges against Albert Gonzalez and ten others, 5 Aug 2008	https://www.justice.gov/archive/opa/pr/2008/August/08-ag-689.html	2026-11-13	Confirmed (as alleged)
19	Microsoft Security Bulletin MS05-039	https://learn.microsoft.com/en-us/security-updates/securitybulletins/2005/ms05-039	2026-11-12	Confirmed
20	US-CERT SA05-221A (CISA archive)	https://www.cisa.gov/news-events/alerts/2005/08/09/microsoft-windows-and-internet-explorer-vulnerabilities	2026-11-12	Confirmed
21	CERT/CC, VU#998653 (Plug and Play)	https://www.kb.cert.org/vuls/id/998653	2026-11-12	Confirmed
22	NVD, CVE-2005-1983	https://nvd.nist.gov/vuln/detail/CVE-2005-1983	2026-11-12, 2026-11-13	Confirmed
23	Microsoft Security Advisory 899588 (Zotob)	https://learn.microsoft.com/en-us/security-updates/securityadvisories/2005/899588	2026-11-12	Confirmed
24	FBI, "FBI Announces Two Arrests in Mytob and Zotob Computer Worm Investigation", 26 Aug 2005	https://archives.fbi.gov/archives/news/pressrel/press-releases/fbi-announces-two-arrests-in-mytob-and-zotob-computer-worm-investigation	2026-11-12, 2026-11-13	Confirmed; Inferred (release date of the worms)
25	US-CERT TA05-180A, VERITAS Backup Exec actively exploited	https://www.cisa.gov/news-events/alerts/2005/06/29/veritas-backup-exec-software-actively-being-exploited	2026-11-12	Confirmed
26	NVD, CVE-2005-0773	https://nvd.nist.gov/vuln/detail/CVE-2005-0773	2026-11-12	Confirmed
27	US-CERT TA05-224A, VERITAS hard-coded credentials	https://www.cisa.gov/news-events/alerts/2005/08/12/veritas-backup-exec-uses-hard-coded-authentication-credentials	2026-11-12	Confirmed
28	Cisco Security Advisory cisco-sa-20050729-ipv6	https://sec.cloudapps.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-20050729-ipv6	2026-11-12	Confirmed
29	Cisco Security Advisory cisco-sa-20050729-ipv6 (cisco.com copy)	https://www.cisco.com/c/en/us/support/docs/csa/cisco-sa-20050729-ipv6.html	2026-11-12	Confirmed
30	US-CERT TA05-210A, Cisco IOS IPv6 vulnerability	https://www.cisa.gov/news-events/alerts/2005/07/29/cisco-ios-ipv6-vulnerability	2026-11-12	Confirmed
31	CERT/CC, VU#312073 (Sony BMG XCP)	https://www.kb.cert.org/vuls/id/312073	2026-11-12, 2026-11-13	Confirmed
32	NVD, CVE-2005-3650	https://nvd.nist.gov/vuln/detail/CVE-2005-3650	2026-11-12	Confirmed

#	Source	URL	Opened	Grade
33	FTC, "Sony BMG Settles FTC Charges", 30 Jan 2007	https://www.ftc.gov/news-events/news/press-releases/2007/01/sony-bmg-settles-ftc-charges	2026-11-12, 2026-11-13	Confirmed
34	US-CERT TA05-362A, Windows Metafile handling buffer overflow	https://www.cisa.gov/news-events/alerts/2005/12/28/microsoft-windows-metafile-handling-buffer-overflow	2026-11-12	Confirmed
35	CERT/CC, VU#181038 (Windows Metafile)	https://www.kb.cert.org/vuls/id/181038	2026-11-12	Confirmed
36	NVD, CVE-2005-4560	https://nvd.nist.gov/vuln/detail/CVE-2005-4560	2026-11-12	Confirmed
37	Microsoft Security Advisory 912840 (WMF)	https://learn.microsoft.com/en-us/security-updates/securityadvisories/2005/912840	2026-11-12	Confirmed
38	Microsoft Security Bulletin MS06-001	https://learn.microsoft.com/en-us/security-updates/securitybulletins/2006/ms06-001	2026-11-12	Confirmed
39	Microsoft Security Bulletin MS05-001	https://learn.microsoft.com/en-us/security-updates/securitybulletins/2005/ms05-001	2026-11-12	Confirmed; Inferred (the bulletin count)
40	Microsoft Security Bulletin MS05-055	https://learn.microsoft.com/en-us/security-updates/securitybulletins/2005/ms05-055	2026-11-12	Confirmed
41	NVD CVE API 2.0, records published in 2005 in four date windows: 1 Jan to 30 Apr (719), 1 May to 28 Aug (2,112), 29 Aug to 26 Dec (1,722), 27 to 31 Dec (457)	https://services.nvd.nist.gov/rest/json/cves/2.0?pubStartDate=2005-01-01T00:00:00.000&pubEndDate=2005-04-30T23:59:59.999 ; https://services.nvd.nist.gov/rest/json/cves/2.0?pubStartDate=2005-05-01T00:00:00.000&pubEndDate=2005-08-28T23:59:59.999 ; https://services.nvd.nist.gov/rest/json/cves/2.0?pubStartDate=2005-08-29T00:00:00.000&pubEndDate=2005-12-26T23:59:59.999 ; https://services.nvd.nist.gov/rest/json/cves/2.0?pubStartDate=2005-12-27T00:00:00.000&pubEndDate=2005-12-31T23:59:59.999	2026-11-12; window counts re-run 2026-11-13	Confirmed
42	Samy Kamkar, "MySpace Worm Explanation" (author's account)	https://samy.pl/myspace/	2026-11-12	Reported
43	US-CERT TA05-189A, Targeted Trojan Email Attacks	https://www.cisa.gov/news-events/alerts/2005/07/08/targeted-trojan-email-attacks	2026-11-12, 2026-11-13	Confirmed; Inferred (the technique mapping)
44	TIME, "The Invasion of the Chinese Cyberspies", 29 Aug 2005	https://time.com/archive/6674509/the-invasion-of-the-chinese-cyberspies/	2026-11-12, 2026-11-13	Reported
45	IEEE Spectrum, "The Athens Affair"	https://spectrum.ieee.org/the-athens-affair	2026-11-12	Reported
46	CISA and partners, AA23-129A, Hunting Russian Intelligence "Snake" Malware, 9 May 2023	https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-129a	2026-11-12	Confirmed; Inferred (operations in 2005)
47	MITRE ATT&CK, Turla (G0010)	https://attack.mitre.org/groups/G0010/	2026-11-12	Confirmed

#	Source	URL	Opened	Grade
48	Kaspersky, "Equation Group: Questions and Answers", February 2015	https://media.kasperskycontenthub.com/wp-content/uploads/sites/43/2018/03/08064459/Equation_group_questions_and_answers.pdf	2026-11-12	Confirmed
49	MITRE ATT&CK, Equation (G0020)	https://attack.mitre.org/groups/G0020/	2026-11-12	Confirmed
50	DOJ, Ancheta arrest, 3 Nov 2005	https://www.justice.gov/archive/criminal/cybercrime/press-releases/2005/anchetaArrest.htm	2026-11-12, 2026-11-13	Confirmed (as alleged)
51	DOJ, Ancheta sentence, 8 May 2006	https://www.justice.gov/archive/criminal/cybercrime/press-releases/2006/anchetaSent.htm	2026-11-12	Confirmed
52	DOJ, Massachusetts juvenile sentenced, 8 Sep 2005	https://www.justice.gov/archive/criminal/cybercrime/press-releases/2005/juvenileSentboston.htm	2026-11-12	Confirmed
53	DOJ, Jacobsen plea, 15 Feb 2005	https://www.justice.gov/archive/criminal/cybercrime/press-releases/2005/jacobsenPlea.htm	2026-11-12	Confirmed
54	DOJ, Greco plea, 21 Mar 2005	https://www.justice.gov/archive/criminal/cybercrime/press-releases/2005/grecoPlea.htm	2026-11-12	Confirmed
55	DOJ, RPCSDBOT juvenile sentenced, 11 Feb 2005	https://www.justice.gov/archive/criminal/cybercrime/press-releases/2005/juvenileSent.htm	2026-11-12	Confirmed
56	DOJ, Lyttle plea, 11 Mar 2005	https://www.justice.gov/archive/criminal/cybercrime/press-releases/2005/lyttlePlea.htm	2026-11-12	Confirmed
57	DOJ, Jiang sentence, 28 Feb 2005	https://www.justice.gov/archive/criminal/cybercrime/press-releases/2005/jiangSent.htm	2026-11-12	Confirmed
58	DOJ, Shadowcrew pleas including Mantovani, 17 Nov 2005	https://www.justice.gov/archive/criminal/cybercrime/press-releases/2005/mantovaniPlea.htm	2026-11-12	Confirmed
59	DOJ, Butler indictment, 2007	https://www.justice.gov/archive/criminal/cybercrime/press-releases/2007/butlerIndict.htm	2026-11-12	Confirmed (as alleged)
60	DOJ, Operation Site Down, June 2005	https://www.justice.gov/archive/opa/pr/2005/June/05_crm_353.htm	2026-11-13	Confirmed
61	BBC News, Sasser author's conviction, 8 Jul 2005	http://news.bbc.co.uk/2/hi/technology/4659329.stm	2026-11-12	Reported
62	GAO, GAO-05-231, Emerging Cybersecurity Issues Threaten Federal Information Systems	`https://www.gao.gov/products/gao-05-231`	2026-11-12	Confirmed
63	Federal Register, 70 FR 15736, Interagency Guidance on Response Programs, 29 Mar 2005	https://www.govinfo.gov/content/pkg/FR-2005-03-29/html/05-5980.htm	2026-11-13	Confirmed
64	OCC Bulletin 2005-13	https://www.occ.gov/news-issuances/bulletins/2005/bulletin-2005-13.html	2026-11-13	Confirmed
65	FDIC FIL-103-2005, Authentication in an Internet Banking Environment	https://www.fdic.gov/news/inactive-financial-institution-letters/2005/fil10305.html	2026-11-13	Confirmed

#	Source	URL	Opened	Grade
66	Energy Policy Act of 2005, Public Law 109-58	https://www.govinfo.gov/content/pkg/PLAW-109publ58/html/PLAW-109publ58.htm	2026-11-13	Confirmed
67	Illinois General Assembly, Public Act 94-36 (Personal Information Protection Act)	`https://www.ilga.gov/Legislation/publicacts/view/094-0036`	2026-11-13	Confirmed
68	NIST, SP 800-53 (original), Recommended Security Controls for Federal Information Systems	https://csrc.nist.gov/pubs/sp/800/53/final	2026-11-12, 2026-11-13	Confirmed
69	NIST, FIPS 201, Personal Identity Verification	https://csrc.nist.gov/pubs/fips/201/final	2026-11-13	Confirmed
70	NIST, SP 800-40 Version 2	https://csrc.nist.gov/pubs/sp/800/40/ver2/final	2026-11-12	Confirmed
71	NIST, SP 800-83	https://csrc.nist.gov/pubs/sp/800/83/final	2026-11-12	Confirmed
72	NIST, SP 800-77	https://csrc.nist.gov/pubs/sp/800/77/final	2026-11-12	Confirmed
73	ISO, ISO/IEC 17799:2005	https://www.iso.org/standard/39612.html	2026-11-12, 2026-11-13	Confirmed
74	ISO, ISO/IEC 27001:2005	https://www.iso.org/standard/42103.html	2026-11-12, 2026-11-13	Confirmed
75	RFC Editor, RFC 4033	https://www.rfc-editor.org/rfc/rfc4033	2026-11-12	Confirmed
76	RFC Editor, RFC 4301	https://www.rfc-editor.org/rfc/rfc4301	2026-11-12	Confirmed
77	Microsoft, "The Trustworthy Computing Security Development Lifecycle", March 2005	https://learn.microsoft.com/en-us/previous-versions/ms995349(v=msdn.10)	2026-11-12	Confirmed
78	FIRST, CVSS v1	https://www.first.org/cvss/v1/	2026-11-12	Confirmed
79	Zero Day Initiative, About	https://www.zerodayinitiative.com/about/	2026-11-12	Confirmed
80	MITRE, CWE history	https://cwe.mitre.org/about/history.html	2026-11-12	Confirmed
81	MITRE, About CAPEC	https://capec.mitre.org/about/index.html	2026-11-12	Confirmed
82	NIST, policy on hash functions	https://csrc.nist.gov/projects/hash-functions/nist-policy-on-hash-functions	2026-11-12	Confirmed
83	TeamStarWolf library, `data/attack/technique_releases.jsonl`	https://github.com/TeamStarWolf/TeamStarWolf/blob/main/data/attack/technique_releases.jsonl	2026-11-12	Inferred (the bindings); Demonstrated (live status)
84	TeamStarWolf library, `data/attack/technique_profiles.jsonl`	https://github.com/TeamStarWolf/TeamStarWolf/blob/main/data/attack/technique_profiles.jsonl	2026-11-13	Demonstrated
85	TeamStarWolf library, `data/attack/software.jsonl` and `groups.jsonl`	https://github.com/TeamStarWolf/TeamStarWolf/blob/main/data/attack/software.jsonl	2026-11-13	Demonstrated

#	Source	URL	Opened	Grade
86	TeamStarWolf library, `data/attack/superseded_by.jsonl`	https://github.com/TeamStarWolf/TeamStarWolf/blob/main/data/attack/superseded_by.jsonl	2026-11-13	Demonstrated
87	TeamStarWolf library, `data/attack/d3fend_countermeasures.jsonl`	https://github.com/TeamStarWolf/TeamStarWolf/blob/main/data/attack/d3fend_countermeasures.jsonl	2026-11-12, 2026-11-13	Confirmed; Demonstrated
88	TeamStarWolf library, `data/weaknesses/cwe.jsonl` and `data/weaknesses/capec.jsonl`	https://github.com/TeamStarWolf/TeamStarWolf/blob/main/data/weaknesses/cwe.jsonl	2026-11-12, 2026-11-13	Inferred (the CWE classes); Demonstrated (names)
89	TeamStarWolf library, `mitre/` page tree (techniques, groups, software, CAPEC, D3FEND and mitigation pages)	https://github.com/TeamStarWolf/TeamStarWolf/tree/main/mitre	2026-11-12, 2026-11-13	Demonstrated
90	TeamStarWolf library, `navigator/library-layers/chronicle-2016.json` (layer format and scoring scale)	https://github.com/TeamStarWolf/TeamStarWolf/blob/main/navigator/library-layers/chronicle-2016.json	2026-11-13	Demonstrated
91	TeamStarWolf library, `case-studies/ECOMMERCE_THREATS.md` (home study)	https://github.com/TeamStarWolf/TeamStarWolf/blob/main/case-studies/ECOMMERCE_THREATS.md	2026-11-12	Confirmed
92	TeamStarWolf library, `case-studies/CYBERCRIME_FOUR_BOOKS.md` (home study)	https://github.com/TeamStarWolf/TeamStarWolf/blob/main/case-studies/CYBERCRIME_FOUR_BOOKS.md	2026-11-12, 2026-11-13	Confirmed
93	TeamStarWolf library, `case-studies/ZERO_DAY_MARKET_EVENTS.md` (home study)	https://github.com/TeamStarWolf/TeamStarWolf/blob/main/case-studies/ZERO_DAY_MARKET_EVENTS.md	2026-11-12	Confirmed
94	TeamStarWolf library, `case-studies/` tree (homes for 2005 events)	https://github.com/TeamStarWolf/TeamStarWolf/tree/main/case-studies	2026-11-12, 2026-11-13	Confirmed; Demonstrated

© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.

© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/

© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/

© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/

The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.

Related references

- Notable Incidents, Threat Actors, Malware Families, CVE Reference
- CWE Reference, CAPEC Reference, D3FEND Reference, Database Security, Web Application Security, Identity and Access Management, Wireless Security, Privacy Engineering, Fraud Framework, GRC and

Compliance, Vulnerability Management, Supply Chain Security, Incident Response, Vulnerability Root Causes, ICS/OT Security, ICS ATT&CK Atlas

- Home studies: E-Commerce Threats; Four Books on Cybercrime; The Zero-Day Market; The Dot-Com Era; Russia-attributed actors; United States actors; China-attributed actors; APT41; Stuxnet; ICS attacks and advisories; Log4Shell; SolarWinds SUNBURST; npm supply-chain attacks; Hugging Face supply chain; The Year 2003 in Intrusions; The Year 2004 in Intrusions
- Series: 1993, 1994, 1995, 1996, 1997, 1998, 1999, 2000, 2001, 2002, 2003, 2004, 2016, 2017, 2018, 2019, 2020, 2021, 2022, 2023, 2024, 2025, 2026
- Techniques: T1190 Exploit Public-Facing Application, T1005 Data from Local System, T1029 Scheduled Transfer, T1078 Valid Accounts, T1078.001 Default Accounts, T1669 Wi-Fi Networks, T1040 Network Sniffing, T1210 Exploitation of Remote Services, T1685 Disable or Modify Tools, T1071 Application Layer Protocol, T1068 Exploitation for Privilege Escalation, T1203 Exploitation for Client Execution, T1189 Drive-by Compromise, T1584.005 Botnet, T1498 Network Denial of Service, T1014 Rootkit, T1564.001 Hidden Files and Directories, T1056.001 Keylogging, T1491.002 External Defacement, T1059.007 JavaScript, T1566.001 Spearphishing Attachment, T1566.002 Spearphishing Link, T1204.002 Malicious File, T1027 Obfuscated Files or Information, T1071.001 Web Protocols, T1082 System Information Discovery, T1135 Network Share Discovery, T1039 Data from Network Shared Drive, T1105 Ingress Tool Transfer, T1041 Exfiltration Over C2 Channel, T1046 Network Service Discovery; object techniques T1480.001, T1564.005, T1120, T1542.002
- CAPEC: CAPEC-63, CAPEC-66, CAPEC-70, CAPEC-100, CAPEC-125, CAPEC-158, CAPEC-163, CAPEC-185, CAPEC-242, CAPEC-300, CAPEC-552, CAPEC-560, CAPEC-568, CAPEC-578
- Groups and software: Turla G0010 and Uroburos S0022, for Snake in use; Equation G0020
- Navigator layers, including this study's layer, chronicle-2005.json